

OWASP Juice Shop

Black-Box Web Application Security Assessment

Problem-statement aligned | Local training target: <http://127.0.0.1:3000>

Assessment type: Black-box, manual testing

Tools: Burp Suite Community Edition; Chrome Developer Tools

Evidence source: Student-submitted screenshots and observations

Assessment scope: Local OWASP Juice Shop instance only; scoreboard excluded

Submission status

The problem statement asks for at least SIX vulnerability reports with manual working proof-of-concept and CVSS v3 scoring. This document contains six assessment entries, but not all six qualify as confirmed, exploited vulnerabilities. It does not claim otherwise. Additional validation is needed before it can honestly be described as satisfying the six-confirmed-vulnerability requirement.

Engagement methodology

Observed workflow: browse the training application; capture requests in Burp Proxy; compare normal and altered requests using Repeater; inspect authentication, cookies, HTTP response headers, error behavior and configuration exposure; document reproducible evidence and mitigations. No scoreboard-guided testing or automated exploitation is claimed.

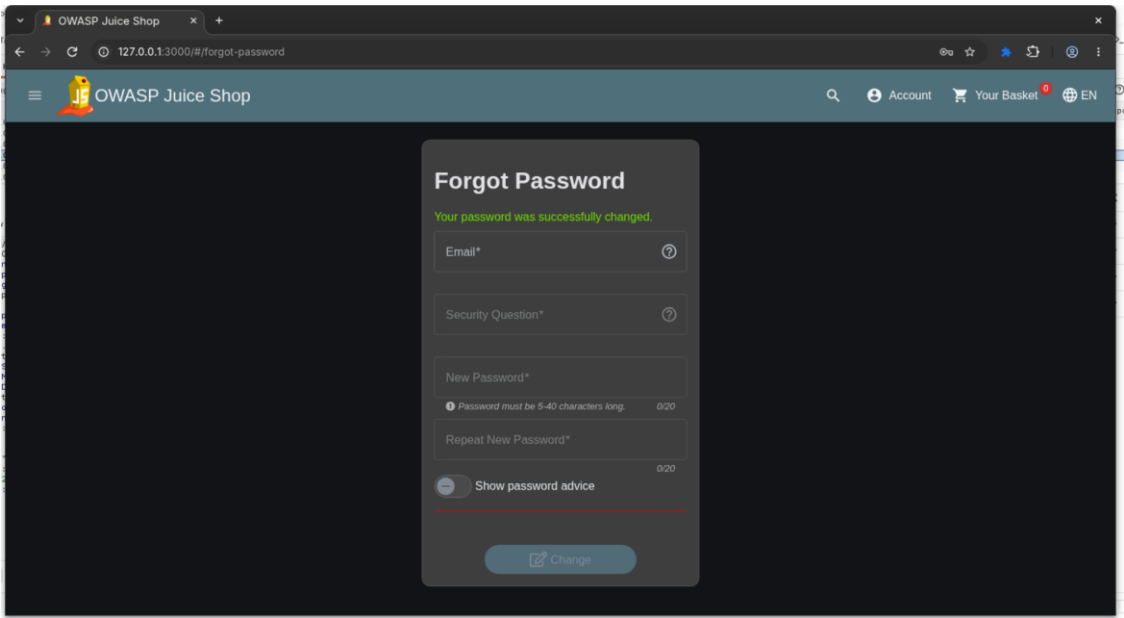
Findings and evidence status

ID	Finding	Severity	Status
F-01	Authentication token cookie without HttpOnly	Medium (provisional)	Confirmed configuration
F-02	Verbose REST error exposes stack trace	Low (provisional)	Confirmed disclosure
F-03	Content-Security-Policy header absent	Low (provisional)	Confirmed on sampled responses
F-04	Password hash returned by reset endpoint	Medium (provisional)	Observed in supplied screenshot; authorization impact unverified
F-05	Wildcard Access-Control-Allow-Origin	Informational / review	Header observed; exploit not established
F-06	Unauthenticated application configuration JSON	Informational / Low	Public response; sensitive exposure unconfirmed

Evidence register

Burp Suite Community Edition v2025.8 - Temporary Project													
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover													
Intercept HTTP history WebSockets history Match and replace Proxy settings													
Filter settings: Hiding CSS and image content, hiding specific extensions													
#	H	Filter settings: Hiding CSS and image content, hiding specific extensions	Params	Edited	Status	code	Length	MIME type	Extension	Title	Notes	TLS	IP
1	http	/127.0.0.1:3000	GET	/	200	9860	HTML			OWASP Juice Shop		127.0.0.1	127.0.0.1
10	http	/127.0.0.1:3000	GET	/socket.io/?EIO=4&transport=pollin	✓	200	326	text	io/			127.0.0.1	127.0.0.1
11	http	/127.0.0.1:3000	GET	/assets/lib/en.json	✓	200	35940	JSON	json			127.0.0.1	127.0.0.1
12	http	/127.0.0.1:3000	GET	/api/challenges?frame=Score%20B	✓	200	662	JSON				127.0.0.1	127.0.0.1
13	http	/127.0.0.1:3000	GET	/rest/admin/application-configuration	✓	200	23966	JSON				127.0.0.1	127.0.0.1
14	http	/127.0.0.1:3000	GET	/rest/languages	✓	200	4603	JSON				127.0.0.1	127.0.0.1
15	http	/127.0.0.1:3000	GET	/rest/admin/application-version	✓	200	404	JSON				127.0.0.1	127.0.0.1
16	http	/127.0.0.1:3000	GET	/api/quantities	✓	200	8016	JSON				127.0.0.1	127.0.0.1
17	http	/127.0.0.1:3000	POST	/socket.io/?EIO=4&transport=pollin	✓	200	215	HTML	io/			127.0.0.1	127.0.0.1
18	http	/127.0.0.1:3000	GET	/rest/products/search?q=	✓	200	16952	JSON				127.0.0.1	127.0.0.1
19	http	/127.0.0.1:3000	GET	/socket.io/?EIO=4&transport=pollin	✓	200	262	text	io/			127.0.0.1	127.0.0.1
21	http	/127.0.0.1:3000	GET	/rest/admin/application-version	✓	304	304					127.0.0.1	127.0.0.1
23	http	/127.0.0.1:3000	GET	/rest/admin/application-configuration	✓	304	306					127.0.0.1	127.0.0.1
24	http	/127.0.0.1:3000	GET	/socket.io/?EIO=4&transport=pollin	✓	200	230	text	io/			127.0.0.1	127.0.0.1
25	http	/127.0.0.1:3000	GET	/rest/admin/application-configuration	✓	304	306					127.0.0.1	127.0.0.1
26	http	/127.0.0.1:3000	GET	/rest/admin/application-configuration	✓	304	306					127.0.0.1	127.0.0.1
27	http	/127.0.0.1:3000	GET	/api/challenges?frame=Score%20B	✓	304	305					127.0.0.1	127.0.0.1
28	http	/127.0.0.1:3000	GET	/rest/admin/application-configuration	✓	304	306					127.0.0.1	127.0.0.1
29	http	/127.0.0.1:3000	GET	/rest/admin/application-configuration	✓	304	306					127.0.0.1	127.0.0.1
47	http	/127.0.0.1:3000	GET	/socket.io/?EIO=4&transport=webs	✓	101	129		io/			127.0.0.1	127.0.0.1
48	http	/127.0.0.1:3000	GET	/rest/admin/application-configuration	✓	304	306					127.0.0.1	127.0.0.1
49	http	/127.0.0.1:3000	GET	/rest/user/whoami	✓	200	394	JSON				127.0.0.1	127.0.0.1
50	http	/127.0.0.1:3000	GET	/rest/user/whoami?fields=email	✓	200	394	JSON				127.0.0.1	127.0.0.1
51	http	/127.0.0.1:3000	POST	/rest/user/login	✓	200	186	JSON				127.0.0.1	127.0.0.1
52	http	/127.0.0.1:3000	GET	/rest/basket/6	✓	200	1406	JSON				127.0.0.1	127.0.0.1
53	http	/127.0.0.1:3000	GET	/rest/user/whoami?fields=email	✓	200	426	JSON				127.0.0.1	127.0.0.1
54	http	/127.0.0.1:3000	GET	/rest/user/whoami	✓	200	518	JSON				127.0.0.1	127.0.0.1
55	http	/127.0.0.1:3000	GET	/rest/products/search?q=	✓	304	306					127.0.0.1	127.0.0.1
56	http	/127.0.0.1:3000	GET	/api/quantities	✓	304	306					127.0.0.1	127.0.0.1

Evidence — Burp HTTP history demonstrating locally scoped requests.



Evidence — Password-reset confirmation for the student-created account.

F-01 — Authentication token cookie without HttpOnly

Severity: Medium (provisional)

Validation status: Confirmed configuration

CVSS v3 assessment: CVSS v3.1: Not reliably scoreable from the cookie attribute alone; medium is a preliminary risk judgment, not a validated CVSS result.

Affected asset: http://127.0.0.1:3000

Description

The browser cookie named token was visible in Chrome Developer Tools without HttpOnly enabled. This is a client-side accessible authentication credential design concern.

Steps to reproduce

- 1. Log in to the local training instance using the self-created test account.
- 2. Open Chrome Developer Tools > Application > Cookies > http://127.0.0.1:3000.
- 3. Inspect the token row and verify that the HttpOnly attribute is not selected.

Proof of concept / observed result

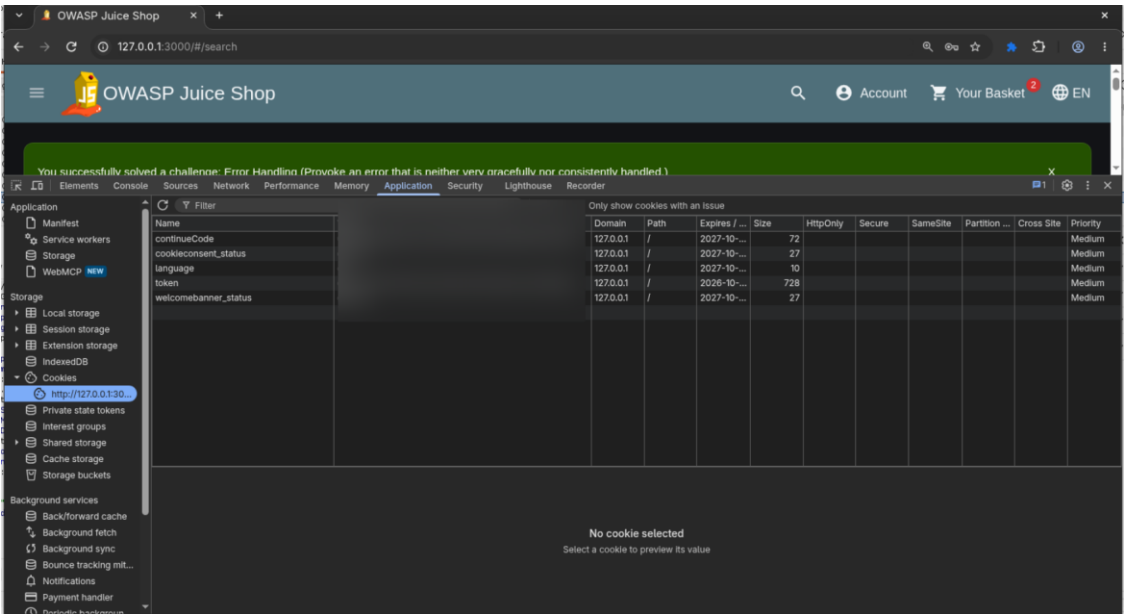
The token cookie is present and its HttpOnly column is unchecked. No token theft or account takeover was demonstrated.

Impact

If same-origin script execution is possible, script may read the cookie, potentially increasing session exposure.

Remediation

Prefer server-managed HttpOnly session cookies where compatible with the architecture; use Secure over HTTPS, appropriate SameSite, and defense-in-depth against XSS.



Evidence — Cookie attributes in Chrome Developer Tools; token value obscured.

F-02 — Verbose REST error exposes stack trace

Severity: Low (provisional)

Validation status: Confirmed disclosure

CVSS v3 assessment: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N — 5.3 (illustrative; severity review required).

Affected asset: http://127.0.0.1:3000

Description

A request for an invalid REST path returned HTTP 500 and a JSON stack trace identifying internal module paths, framework functions and application file locations.

Steps to reproduce

1. Open Burp Repeater for the local instance.
2. Send GET /rest/nonexistent-test-resource-12345 with Host: 127.0.0.1:3000.
3. Observe HTTP 500 and the detailed error.stack JSON field.

Proof of concept / observed result

The captured HTTP 500 response contains internal file paths and stack frames. This confirms verbose error disclosure, not arbitrary code execution.

Impact

An unauthenticated visitor may learn implementation details useful for understanding application internals.

Remediation

Use generic external error messages, log detailed stack traces only server-side, and return suitable HTTP statuses.

The screenshot displays the Burp Suite Repeater interface. The Request tab shows a GET request to `/rest/nonexistent-test-resource-12345` with Host: 127.0.0.1:3000. The Response tab shows an HTTP 500 Internal Server Error with a detailed JSON error message. The error message includes a stack trace with the following details:

- Message: "Unexpected path: /rest/nonexistent-test-resource-12345".
- Stack trace (from top to bottom):
 - at /juice-shop/build/routes/angular.js:18:18
 - at /juice-shop/build/lib/util.js:29:5:20
 - at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
 - at /juice-shop/node_modules/express/lib/router/index.js:328:13
 - at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
 - at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
 - at /juice-shop/build/routes/verify.js:295:5
 - at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
 - at /juice-shop/node_modules/express/lib/router/index.js:328:13
 - at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
 - at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
 - at /juice-shop/build/lib/insecurity.js:228:5
 - at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
 - at /juice-shop/node_modules/express/lib/router/index.js:328:13

Evidence — Burp request and verbose HTTP 500 response.

F-03 — Content-Security-Policy header absent

Severity: Low (provisional)

Validation status: Confirmed on sampled responses

CVSS v3 assessment: CVSS v3.1: N/A without a demonstrated exploit chain; preliminary Low hardening observation.

Affected asset: http://127.0.0.1:3000

Description

The inspected HTML/JSON responses did not include a Content-Security-Policy response header. CSP is a browser defense-in-depth control.

Steps to reproduce

1. Send GET / to the local instance using Burp Repeater.
2. Inspect the response header block.
3. Check for Content-Security-Policy; it is absent in the captured response.

Proof of concept / observed result

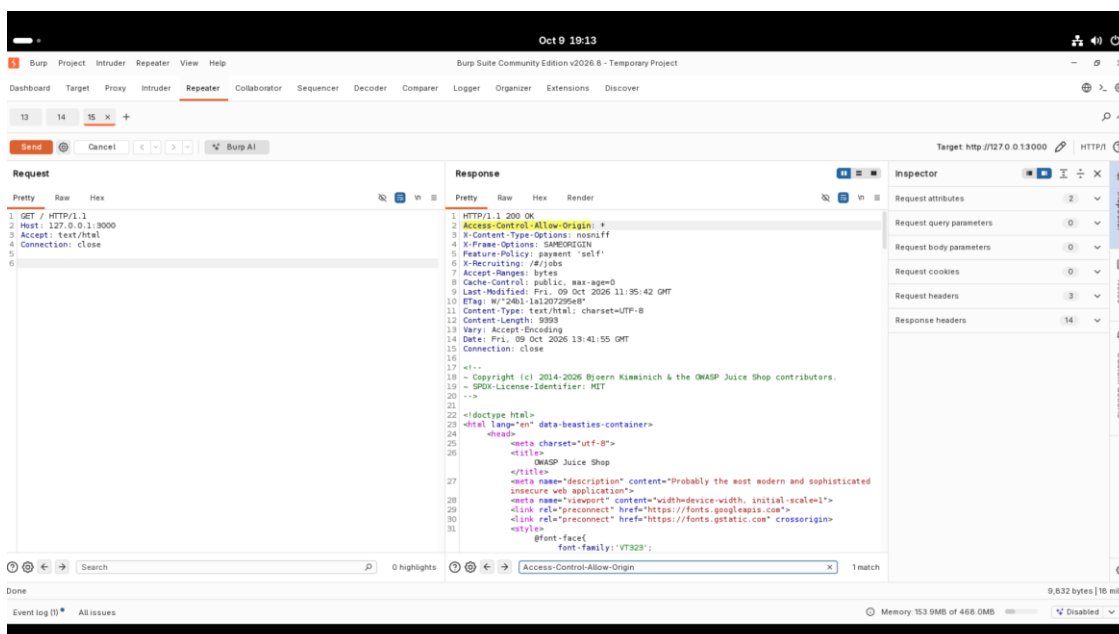
Response-header screenshot documents that CSP is not present in the inspected response; this does not by itself demonstrate XSS.

Impact

A missing CSP removes one mitigation that could limit the effects of a separate browser-side injection vulnerability.

Remediation

Develop and test a restrictive CSP compatible with the application, initially using report-only mode as appropriate.



Evidence — Burp response-header inspection.

F-04 — Password hash returned by reset endpoint

Severity: Medium (provisional)

Validation status: Observed in supplied screenshot; authorization impact unverified

CVSS v3 assessment: CVSS v3.1: N/A pending proof of unauthorized access and demonstrable impact.

Affected asset: http://127.0.0.1:3000

Description

The original Burp screenshot of POST /rest/user/reset-password shows a successful response containing a user object with a password field holding a hash-like value. This is unnecessary disclosure of credential-derived data in a response.

Steps to reproduce

1. Use only the student-created account in the local Juice Shop.
2. Complete the forgot-password flow and capture POST /rest/user/reset-password in Burp.
3. Inspect the response user object for the password field; do not include its value in a shared report.

Proof of concept / observed result

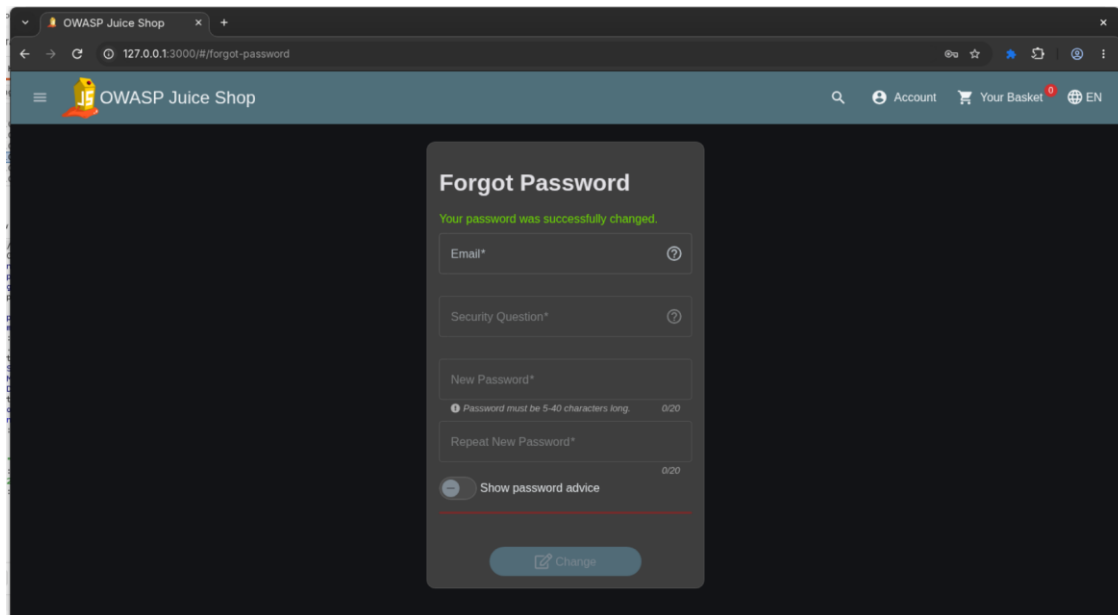
The original submitted screenshot shows the password field in a successful reset response. The evidence does not establish access to another user's hash.

Impact

If exposed beyond the legitimate account owner, password hashes could increase offline guessing risk.

Remediation

Exclude password hashes and other credential material from API serialization; return only the minimum confirmation data.



Evidence — Successful password-reset confirmation; original raw Burp evidence remains in source document.

F-05 — Wildcard Access-Control-Allow-Origin

Severity: Informational / review

Validation status: Header observed; exploit not established

CVSS v3 assessment: CVSS v3.1: N/A — no cross-origin sensitive data access was demonstrated.

Affected asset: http://127.0.0.1:3000

Description

Burp responses include Access-Control-Allow-Origin: *. The OPTIONS response also advertises several methods. A wildcard CORS header is not automatically an exploitable vulnerability.

Steps to reproduce

1. Send OPTIONS / to the local Juice Shop through Burp Repeater.
2. Inspect Access-Control-Allow-Origin and Access-Control-Allow-Methods.
3. Record the headers without inferring that protected data is cross-origin accessible.

Proof of concept / observed result

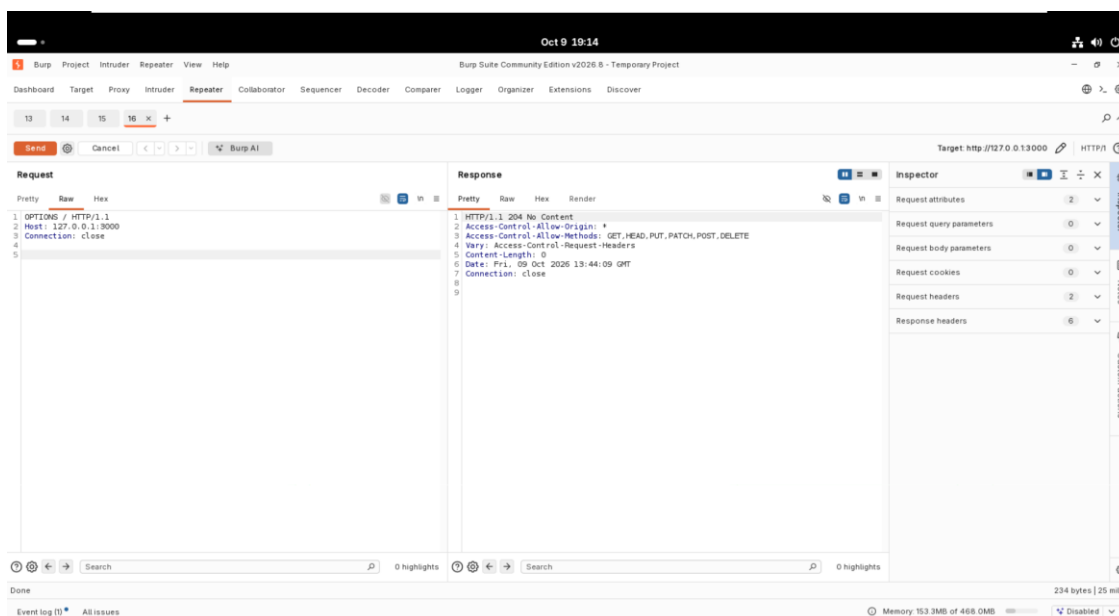
OPTIONS returned 204 No Content with wildcard origin and advertised methods. No browser-based cross-origin data extraction was demonstrated.

Impact

Impact depends on whether sensitive responses are available to unauthenticated cross-origin reads and other policy details.

Remediation

Review the CORS policy endpoint-by-endpoint and restrict origins where sensitive cross-origin access is not intended.



Evidence — Burp OPTIONS request and CORS/method response headers.

F-06 — Unauthenticated application configuration JSON

Severity: Informational / Low

Validation status: Public response; sensitive exposure unconfirmed

CVSS v3 assessment: CVSS v3.1: N/A — no sensitive values or protected access were demonstrated.

Affected asset: http://127.0.0.1:3000

Description

An unauthenticated GET /rest/admin/application-configuration returned HTTP 200 with application settings and branding information. The reviewed portion did not confirm secret exposure.

Steps to reproduce

1. In Burp Repeater, send GET /rest/admin/application-configuration to the local instance without an Authorization header.
2. Inspect the 200 JSON response.
3. Identify public application settings; do not assume every field is confidential.

Proof of concept / observed result

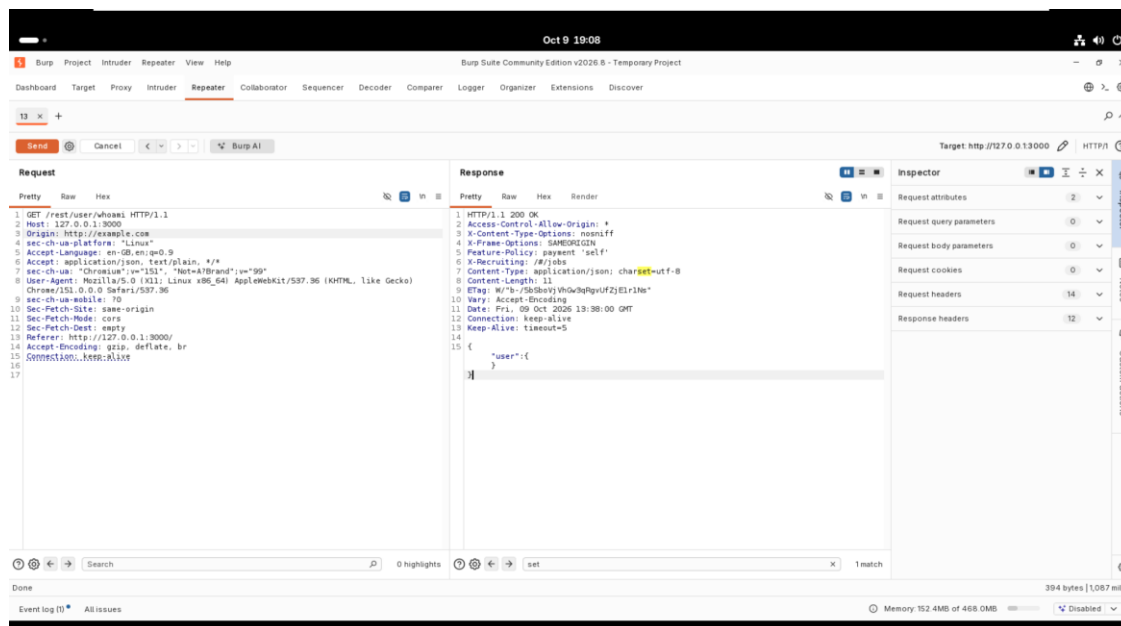
The screenshot documents a public JSON configuration response containing application branding and server settings.

Impact

Potential information disclosure if internal-only or secret configuration fields are returned; not confirmed in current evidence.

Remediation

Classify configuration fields and ensure secrets/internal-only settings are never serialized to unauthenticated clients.



Evidence — Unauthenticated application configuration response.

Limitations and work still required

The source problem statement requires six manually exploited vulnerabilities, each with working PoC and CVSS v3 score/vector. The supplied evidence does not meet that threshold. Entries F-05 and F-06 are primarily review observations, and F-03 is a hardening weakness without an exploitation chain. F-04 requires authorization-impact verification. No exploit or CVSS score has been fabricated to satisfy the count.

For submission, attach an original Burp request/response screenshot for each claimed finding. The password-reset API evidence should be included only after redacting the email address, password, hash and any active authentication tokens. The original screenshots may be consulted for validation; redacted summaries do not replace proof of concept.

Reference and scope notes

Source: “Problem Statement: Juice Shop Online Store” supplied by the user; student-submitted “Final pro.docx”; local OWASP Juice Shop training application. No claim is made that the scoreboard was consulted. This report is a factual record of observed tests, not a claim of a complete six-vulnerability exploitation engagement.